

Lista de Exercícios para Avaliação

Unidade 1 — Segurança de redes locais e de longa distância · Subunidade 1.1 — Introdução a testes de invasão

Nome do(a) aluno(a): Maria Antônia Espinosa Woltmann	Data: 10 / 08 / 2026
Professor: José Carlos Neto	Valor: 3,0 pontos (Listas/Prática — Av1)

Instruções

Responda a todas as questões de forma individual, com justificativa quando solicitado. Cálculos devem ser demonstrados — a resposta final sem o desenvolvimento não pontua integralmente. Consultas ao material de aula são permitidas; consulta a colegas, não.

Parte 1 — Conceitos de rede

1. [Conceitual] Explique a função de cada uma das quatro camadas do modelo TCP/IP, citando um protocolo de exemplo para cada uma.

Aplicação (4): HTTP, DNS, SSH, FTP

Define como aplicações trocam dados, é a camada mais exposta à ataques.

HTTP/HTTPS: navegação web - o S significa que o tráfego é criptografado

DNS: traduz nomes em endereços IP

SSH: acesso remoto administrativo criptografado

FTP: transferência de arquivos - sem criptografia

Transporte (3): TCP e UDP

Organiza a entrega de dados entre processos

TCP: confiável e orientado a conexão

UDP: rápido e sem conexão, envia os dados sem garantir entrega e ordem.

Internet (2): IP e ICMP

Responsável por endereçar hosts e encaminhar pacotes entre redes diferentes

IP: endereça cada host de forma única e leva o pacote de origem até o destino, rede após rede

Roteamento: Cada roteador decide, com base na tabela de rotas, para qual próximo salto encaminhar o pacote.

ICMP: Protocolo de controle e diagnóstico, usado por ferramentas como ping e traceroute, e também por técnicas de reconhecimento de rede.

Acesso à rede (1): Ethernet, Wi-Fi, MAC, ARP

Coloca os dados fisicamente no meio de transmissão (cabos, fibra ou rádio)

Ethernet: padrão para redes cabeadas locais, organiza os dados em frames endereçados por MAC

Endereço MAC: identificador físico, único por fabricante, gravado na placa de rede, usado apenas dentro do mesmo segmento local.

Wi-Fi: versão sem fio do mesmo princípio, com desafios extras de segurança pela natureza aberta do meio de transmissão

ARP: traduz endereço IP em endereço MAC dentro da rede local, alvo clássico de ataque de interceptação (ARP spoofing)

2. [Conceitual] Diferencie TCP e UDP, citando ao menos duas características de cada um e um exemplo de aplicação que utiliza cada protocolo.

TCP: confiável e orientado a conexão, HTTP/HTTPS

UDP: rápido e sem conexão, envia os dados sem garantir entrega e ordem, Streaming/VoIP

3. [Conceitual] O que é NAT e por que ele continua sendo necessário na maioria das redes atuais, mesmo com a existência do IPv6?

Network Address Translation:

Traduz endereços privados (internos) em um único endereço público, na saída para a internet.

Economiza IPs públicos: Toda uma rede local sai para a internet usando um único endereço IPv4 público — essencial diante do esgotamento do IPv4.

Ganho de segurança indireto: Hosts internos não são diretamente endereçáveis pela internet — um invasor externo não consegue simplesmente "apontar" para eles.

Não substitui um firewall: NAT não foi desenhado como controle de segurança — é sempre complementado por regras explícitas de firewall.

Parte 2 — Endereçamento e cálculo de sub-redes

4. **[Cálculo]** Para o bloco 172.16.0.0/22, calcule: (a) a máscara de sub-rede em notação decimal; (b) a quantidade de hosts utilizáveis; (c) o endereço de broadcast.

172.16.0.0/22

↳ $32 - 22 = 10 \text{ bits}$

MÁSCARA: 124 → 255.255.255.0
122 → 255.255.252.0

HOSTS: $2^{10} - 2$
 $1024 - 2 = 1022$

BROADCAST: 255.255.252.0
↳ $256 - 252 = 4$ → GALTO DA REDE.

172.16.0.0
172.16.4.0
⋮
172.16.3.255

5. **[Cálculo]** Divida o bloco 200.10.5.0/24 em 8 sub-redes de tamanho igual. Indique a nova máscara (CIDR) e liste os 8 blocos resultantes.

200.10.5.0/24

n $2^3 = 8$ bits $27 \rightarrow 255.255.255.224$ $256 - 224 = 32$

SUB-REDE	ENDEREÇO	BROADCAST
1	200.10.5.0/27	200.10.5.31
2	200.10.5.32/27	200.10.5.63
3	200.10.5.64/27	200.10.5.95
4	200.10.5.96/27	200.10.5.127
5	200.10.5.128/27	200.10.5.159
6	200.10.5.160/27	200.10.5.191
7	200.10.5.192/27	200.10.5.223
8	200.10.5.224/27	200.10.5.255

6. **[Cálculo]** Os hosts 10.20.30.10/28 e 10.20.30.30/28 estão na mesma sub-rede? Demonstre o cálculo que justifica sua resposta

10.20.30.10/28
10.20.30.30/28

$1/28 \rightarrow 255.255.255.240$
 $256 - 240 = 16$

10.20.30.10 }
10.20.30.0 — 10.20.30.15 {
REDE: 10.20.30.0
HOSTS: 10.20.30.1 — 10.20.30.14
BROADCAST: 10.20.30.15

10.20.30.30 }
10.20.30.16 — 10.20.30.31 {
REDE: 10.20.30.16
HOSTS: 10.20.30.17 — 10.20.30.30
BROADCAST: 10.20.30.31

* SUB REDES DISTINTAS!

Parte 3 — Serviços, ataques e testes de invasão

7. **[Aplicação]** Complete a tabela abaixo com o protocolo de transporte (TCP ou UDP) e o serviço correspondente a cada porta.

Porta	Protocolo (TCP/UDP)	Serviço
21	TCP	FTP
25	TCP	SMTP
110	TCP	POP3
143	TCP	IMAP
3306	TCP	MySQL

8. **[Conceitual]** Diferencie os três tipos de teste de invasão — black box, grey box e white box — e indique uma situação em que cada um seria o mais indicado.

Black Box: o testador não possui informações sobre o sistema e simula um ataque externo. Indicado para verificar a segurança do sistema contra invasores externos.

Grey Box: o testador possui informações parciais sobre o sistema, simulando um usuário com algum nível de acesso.

Indicado para avaliar possíveis ataques realizados por usuários autenticados.

White Box: o testador possui informações completas sobre o sistema, podendo ter acesso ao código-fonte e à arquitetura.

Indicado para uma análise aprofundada da aplicação e identificação de vulnerabilidades internas.

9. [Conceitual] Segundo a Lei 12.737/2012, por que um teste de invasão realizado sem autorização formal é considerado crime, mesmo quando feito com boas intenções?

Um teste de invasão sem autorização formal pode ser considerado crime porque o acesso a um dispositivo ou sistema sem o consentimento do proprietário pode caracterizar invasão indevida. A boa intenção do testador não elimina a necessidade de autorização.

10. [Dissertativa] Cite dois controles de rede vistos em aula (por exemplo: firewall, VLAN, MFA, segmentação) e explique como cada um reduz a superfície de ataque em uma rede corporativa.

FireWalls e ACLS

Decidem, pacote a pacote, o que entra e o que sai com base em regras explícitas.

Firewall: Analisa o tráfego que passa por ele e aplica regras: permite ou bloqueia com base em IP de origem/destino, porta e protocolo.

ACL: Lista ordenada de regras de permissão/negação, aplicada em um roteador ou switch — a lógica por trás de muitos firewalls.

VLANS e segmentação de rede

dividir uma rede física em várias redes lógicas isoladas, mesmo cabo, tráfego separado.

Isolamento por finalidade: Rede de convidados, rede administrativa e rede de servidores em VLANs separadas — mesmo compartilhando o mesmo switch físico

Redução da superfície de ataque: Um host comprometido em uma VLAN não enxerga diretamente hosts de outra, limita o "movimento lateral" de um invasor.

Organização e desempenho: Também reduz tráfego de broadcast desnecessário e organiza a rede por departamento ou função.

GABARITO — USO DO PROFESSOR

Referências de correção — aceitar respostas equivalentes, desde que corretamente justificadas.

1. Camadas do TCP/IP

Aplicação (HTTP, DNS, SSH, FTP) — troca de dados entre programas; Transporte (TCP, UDP) — entrega entre processos, com ou sem garantia; Internet/Rede (IP, ICMP) — endereçamento e roteamento entre redes; Acesso à rede (Ethernet, Wi-Fi) — transmissão física dos bits.

2. TCP x UDP

TCP: confiável, orientado a conexão, garante ordem e entrega (three-way handshake) — ex.: HTTP, SSH. UDP: sem conexão, mais rápido, não garante entrega/ordem — ex.: DNS, streaming, VoIP.

3. NAT

Traduz endereços privados internos em um único IP público, permitindo que vários dispositivos compartilhem um IPv4 — ainda essencial pelo esgotamento do IPv4 e pela adoção parcial/gradual do IPv6.

4. 172.16.0.0/22

(a) Máscara: 255.255.252.0. (b) Hosts utilizáveis: $2^{10} - 2 = 1022$. (c) Broadcast: 172.16.3.255.

5. 200.10.5.0/24 em 8 sub-redes

Nova máscara: /27. Blocos: 200.10.5.0/27, .32/27, .64/27, .96/27, .128/27, .160/27, .192/27, .224/27.

6. 10.20.30.10/28 e 10.20.30.30/28

Não estão na mesma sub-rede: cada bloco /28 tem 16 endereços; 10.20.30.10 pertence a 10.20.30.0/28 (0–15) e 10.20.30.30 pertence a 10.20.30.16/28 (16–31).

7. Tabela de portas

21 → TCP → FTP (controle) · 25 → TCP → SMTP (envio de e-mail) · 110 → TCP → POP3 · 143 → TCP → IMAP · 3306 → TCP → MySQL

8. Tipos de teste de invasão

Black box: nenhuma informação prévia — simula atacante externo. Grey box: informação parcial (ex.: conta comum) — simula ameaça interna limitada. White box: acesso completo — foca profundidade, não descoberta.

9. Lei 12.737/2012

A lei tipifica como crime a invasão de dispositivo informático mediante violação indevida de mecanismo de segurança — a intenção declarada não afasta o crime; só a autorização formal do responsável pelo sistema o faz.

10. Controles de rede (resposta aberta)

Aceitar qualquer combinação coerente — ex.: Firewall/ACL filtram tráfego por regra; VLAN isola segmentos e limita movimento lateral; MFA reduz o impacto de uma senha vazada; segmentação limita o alcance de um host comprometido.